

/
CONFIDENTIAL

API SECURITY AUDIT REPORT

API

vAmPI
Scan

2026-02-27
15:36:43

#14

http://
vampi:
5000

(Executive Summary)

vAmPI Scan Assignment	API	BFLA, BOLA, Mass
	7	
	AI	

(Detailed Findings)

1. Mass Assignment ()

MEDIUM SEVERITY

POST /users/v1/login

Status: 200 with extra fields

1. (Business Impact Analysis)

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	(DTO)	(Allow-list)
FastAPI	Pydantic	dict

2. Broken Function Level Authorization (BFLA)

HIGH SEVERITY

GET /users/v1/_debug

Status: 200

1. (Business Impact Analysis)

Allowing low-privilege users to access administrative functions.

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	(RBAC)
	API

3. Broken Function Level Authorization (BFLA)

HIGH SEVERITY

GET /users/v1

Status: 200

1. (Business Impact Analysis)

Allowing low-privilege users to access administrative functions.

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	(RBAC)
	API

© 2026 AI API Security Scanner - Generated for Research & Audit Purposes

4. Excessive Data Exposure ()

MEDIUM SEVERITY

GET /users/v1/_debug

Exposed fields: ['password']

1. (Business Impact Analysis)

()

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	API	Schema
----	-----	--------

5. Broken Object Level Authorization (BOLA)

HIGH SEVERITY

GET /users/v1/admin

Status: 200

1. (Business Impact Analysis)

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	API	({id})
	ID ()	UUID SQL user_id

6. Mass Assignment ()

MEDIUM SEVERITY

POST /users/v1/register

Status: 200 with extra fields

1. (Business Impact Analysis)

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	(DTO)	(Allow-list)	
FastAPI	Pydantic		dict

7. Lack of Resources & Rate Limiting

MEDIUM SEVERITY

POST /users/v1/login

Processed 15 burst requests with no 429 response

1. (Business Impact Analysis)

API	(Brute-force)	(DoS)
-----	---------------	-------

2. (Technical Deep Dive)

3. (Remediation Strategy)

AI	API	(Throttling)	(Login)
	Redis	API	(Kong, Nginx)

(Compliance Disclaimer)

API (LLM)
Secure SDLC

- OWASP API Security Top 10
- ISO/IEC 27001 Information security management
- NIST Cybersecurity Framework